🔎 Fase 2: Fingerprinting: Fuzzing y Directorios

🧪 Fuzzing y descubrimiento de Directorios Web

Con el objetivo de identificar posibles **directorios, rutas o recursos ocultos** dentro de la aplicación web, se realizó un proceso de **fuzzing de contenido web** sobre el dominio principal del objetivo. Esta técnica consiste en probar múltiples rutas posibles utilizando listas de palabras (wordlists) para detectar endpoints existentes que no se encuentran visibles en la navegación normal del sitio.

🛠️ Herramienta utilizada

```
ffuf
```

FFUF (Fuzz Faster U Fool) es una herramienta de fuzzing web que permite descubrir directorios, archivos y endpoints ocultos mediante el uso de listas de palabras aplicadas sobre una URL objetivo.

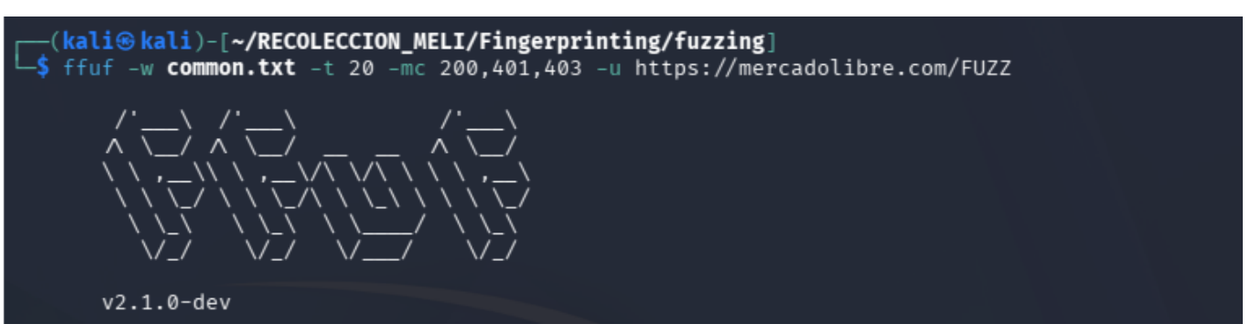
💻 Comandos ejecutados

Primero se descargó una **wordlist de contenido web** desde el repositorio de SecLists:

```
wget
https://raw.githubusercontent.com/danielmiessler/SecLists/refs/heads/master/Di
scovery/Web-Content/common.txt
```

Esta lista contiene nombres de rutas y archivos comunes utilizados para descubrir recursos dentro de aplicaciones web.

Posteriormente se ejecutó el proceso de fuzzing sobre el dominio principal utilizando la wordlist descargada:




```
ffuf -w common.txt -t 20 -mc 200,401,403 -u https://mercadolibre.com/FUZZ
```

Parámetros utilizados:

- `-w` → wordlist utilizada para el fuzzing
- `-t 20` → número de hilos concurrentes

- `-mc 200,401,403` → muestra respuestas HTTP consideradas relevantes
- `FUZZ` → punto donde se insertan las palabras de la lista

📊 Resultados obtenidos

Durante el proceso se analizaron múltiples rutas potenciales dentro del dominio principal del objetivo. Sin embargo, **no se identificaron directorios o recursos relevantes adicionales** que respondieran con códigos de estado indicativos de contenido accesible.

```
~nobody                 [Status: 403, Size: 2585, Words: 554, Lines: 99, Duration: 19ms]
zt                      [Status: 403, Size: 2585, Words: 554, Lines: 99, Duration: 21ms]
~lp                     [Status: 403, Size: 2585, Words: 554, Lines: 99, Duration: 20ms]
~ftp                    [Status: 403, Size: 2585, Words: 554, Lines: 99, Duration: 21ms]
~log                    [Status: 403, Size: 2585, Words: 554, Lines: 99, Duration: 15ms]
~mail                   [Status: 403, Size: 2585, Words: 554, Lines: 99, Duration: 19ms]
~adm                    [Status: 403, Size: 2585, Words: 554, Lines: 99, Duration: 21ms]
zope                    [Status: 403, Size: 2585, Words: 554, Lines: 99, Duration: 21ms]
~httpd                  [Status: 403, Size: 2585, Words: 554, Lines: 99, Duration: 15ms]
~root                   [Status: 403, Size: 2585, Words: 554, Lines: 99, Duration: 20ms]
~tmp                    [Status: 403, Size: 2585, Words: 554, Lines: 99, Duration: 18ms]
~test                   [Status: 403, Size: 2585, Words: 554, Lines: 99, Duration: 18ms]
~sys                    [Status: 403, Size: 2585, Words: 554, Lines: 99, Duration: 21ms]
~sysadmin               [Status: 403, Size: 2585, Words: 554, Lines: 99, Duration: 22ms]
~user                   [Status: 403, Size: 2585, Words: 554, Lines: 99, Duration: 22ms]
~sysadm                 [Status: 403, Size: 2585, Words: 554, Lines: 99, Duration: 22ms]
~www                    [Status: 403, Size: 2585, Words: 554, Lines: 99, Duration: 19ms]
~webmaster              [Status: 403, Size: 2585, Words: 554, Lines: 99, Duration: 22ms]
dns-query?dns=q80BAAABAAAAAAAAAA3d3dwdleGFtcGxlA2NvbQAAAQAB [Status: 403, Size: 2585, Words: 554, Lines: 9
dns-query?name=google.com&type=A [Status: 403, Size: 2585, Words: 554, Lines: 99, Duration: 16ms]
sse                     [Status: 403, Size: 2585, Words: 554, Lines: 99, Duration: 16ms]
mcp                     [Status: 403, Size: 2585, Words: 554, Lines: 99, Duration: 17ms]
mcp/message             [Status: 403, Size: 2585, Words: 554, Lines: 99, Duration: 15ms]
mcp/transport           [Status: 403, Size: 2585, Words: 554, Lines: 99, Duration: 17ms]
:: Progress: [4751/4751] :: Job [1/1] :: 781 req/sec :: Duration: [0:00:05] :: Errors: 0 ::
```

Las respuestas obtenidas correspondían principalmente a comportamientos esperados dentro de la infraestructura del sitio.

🧠 Interpretación del resultado

La ausencia de resultados relevantes sugiere que el sitio se encuentra correctamente configurado para **no exponer directorios o rutas comunes utilizadas en este tipo de pruebas**, lo cual es consistente con infraestructuras protegidas mediante **CDN y mecanismos de seguridad adicionales**.

📄 Conclusión

El proceso de fuzzing permitió verificar la presencia de posibles rutas o recursos ocultos dentro del dominio principal del objetivo. En este caso, **no se identificaron directorios adicionales relevantes**, lo que indica que el sitio no expone rutas comunes que puedan ser descubiertas mediante una wordlist básica de contenido web.